Incident Response

Summary

Between 13:11 and 15:08, the system experienced a coordinated multi-vector attack targeting service availability, flags, and administrative access. The primary objectives of the adversary were **Persistence** via malicious automation, **Exfiltration** via web vulnerabilities, and **Denial of Management (DoM)**. Through manual intervention, service hardening, and forensic analysis, all identified intrusions have been mitigated, and service availability has been restored.

---

1. Persistence via Malicious Cron Jobs

- **Detection & Evidence:** At 14:42, the team identified active "killer processes" at **MGMT SSH**. Investigation of the root crontab revealed multiple `@reboot` entries pointing to `/tmp/svc` and `/tmp/.cache/svc`.
- **Analysis:** These scripts acted as a "watchdog" mechanism. By triggering on reboot, the malware ensured that even after a system restart, services like **MGMT SSH**, **WWW SSH**, and **TICKETS HTTP** would be immediately terminated.
- **Mitigation:** * Deleted all unauthorized crontab entries.
  - Terminated active processes linked to `/tmp/svc`.
  - Applied `snapshot + restart` to restore service state.

2. SQL Injection (SQLi) & Data Exfiltration

- **Detection & Evidence:** High frequency of HTTP GET/POST requests to the Flask backend (Port 5000) contained SQL syntax (e.g., `' OR 1=1 --`). Additionally, a new unknown file, `slnx.sqlite`, was discovered at 14:42.
- **Analysis:** The application's use of `db.session.execute()` with unsanitized strings allowed for an SQLi vulnerability. Attackers used this to exfiltrate **Bus** and **Train** flags from the `transit` database. The `slnx.sqlite` file suggests a secondary database was being used to "feed" or stage exfiltrated data.
- **Mitigation:**
  - Identified and terminated the process interacting with the unauthorized `slnx.sqlite` database.
  - Restarted the HTTP port (initially found down at 13:11) using `.net run` to restore the legitimate service environment.

3. SSH Service Sabotage & Unauthorized Access

- **Detection & Evidence:** * **13:41:** WWW SSH server went down.

    - **14:57:** Forensic audit of `/etc/ssh/sshd_config` showed `PermitRootLogin` and `PasswordAuthentication` were both set to `yes`.
    - **Indicators:** Attackers renamed the service to `sshd.service` or modified unit files to cause "Unit not found" errors during recovery.
- **Analysis:** The attackers likely utilized a **backdoored PAM module** to log in as root using a master password. This allowed them to manipulate flags at `/etc/blue_flag.txt` and `/etc/team22_mgmt-etc.flag`.
- **Mitigation:**
    - **Hardening:** Changed `PermitRootLogin` and `PasswordAuthentication` to `no` at 15:08.
    - **Integrity:** Changed root password via `sudo passwd root`.
    - **Persistence Defenses:** Applied `chattr +i` to flag files to make them immutable, preventing unauthorized `chown` or `chmod` attempts.
    - **Recovery:** Restored SSH via `systemctl restart sshd`.

4. Identity & Directory Service Interference (AD/LDAP)

- **Detection & Evidence:** At 13:41, the AD LDAP service failed. A check using `netstat -ano | findstr :389` confirmed the port was unresponsive.
- **Analysis:** This was a targeted strike to break authentication across the environment, coinciding with the removal of the `CDC` user from the front-end at 13:37.
- **Mitigation:**
    - Performed a force termination of the hung process.
    - Restarted the service using `net start ntds` to restore directory availability.

5. Process Masquerading & Internal Errors

- **Detection & Evidence:** At 13:30, a "fake admin" process was discovered on the admin server, masquerading as a standard user to avoid detection.
- **Analysis:** This was likely the source of the "Internal Server Error" on the admin login port, as the masqueraded process intercepted legitimate traffic.
- **Mitigation:**
    - Manual process termination of the PID associated with the fake admin.
    - Validation of the HTTP Connection Pool (Port 80) to resolve the `www login` failures.

Impact Assessment

Intrusion	Impact Level	Impact Summary
Cron Persistence	High	Constant service downtime for SSH and HTTP.

Intrusion	Impact Level	Impact Summary
SQL Injection	Critical	Exfiltration of Bus and Train flags; compromise of `transit` DB.
PAM Backdoor	Critical	Full root access to MGMT and WWW servers.
Service Sabotage	Medium	Denial of Management (DoM) preventing rapid response.

Summary of Evidence

- **Log Files:** Documented SSH configuration changes and Crontab `@reboot` entries.
- **Network Activity:** SQL syntax detected in Port 5000 traffic logs.
- **System State:** Unauthorized file presence (`/tmp/svc`, `slnx.sqlite`) and modified file attributes.